ATMIYA UNIVERSITY
RAJKOT, GUJARAT (INDIA)

ATMIYA DEVELOPER STUDENTS CLUB PRESENTS

CODE CARNIVAL 3.0

AegisRAG · Answers only from the files you are allowed to read · Navadeep Gandloju & Adithya Mamidala

TEAM NAME	TEAM ID	TEAM LEADER
The Boor Bots	SJX3	Navadeep Gandloju

PROBLEM STATEMENT TITLE	THEME / TRACK
PS-01 · Secure Multi-Modal RAG System with Access Control	AI Security · Enterprise RAG

01 · THE TARGET

PROBLEM STATEMENT & UNDERSTANDING

PROBLEM STATEMENT

- Companies want one AI assistant over all internal files, but every file has its own readers
- Files mix PDFs, scans, photos and spreadsheets; access rules must hold for every format
- **Who it hurts:** employees who leak by accident, admins who carry the risk, auditors who can't prove who saw what

OUR THESIS
Authorization is not a prompt instruction. It is compiled into the SQL query.

WHERE TODAY'S RAG FAILS → HOW AEGISRAG FIXES IT

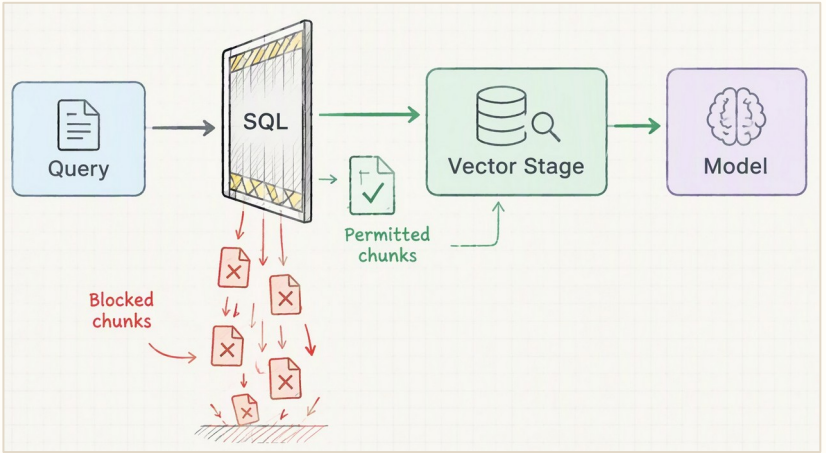
Filters after ranking: leaks metadata, wastes top-K	**Permission filter runs inside SQL, before any ranking**
Access rules written in the prompt fall to injection	**Model only ever receives chunks the user may read**
LLMs guess totals and invent citations	**Math runs in code; every claim checked against its source**
Old chat answers survive revoked access	**History re-checked on open; lost answers are redacted**

02 · THE PLAN

PROPOSED SOLUTION

OUR IDEA

- Permissions are compiled into the retrieval SQL query
- Restricted chunks are never loaded, ranked or sent to the model
- Spreadsheet totals computed in code, on permitted rows only
- Every claim checked against its source, then highlighted
- Ask by voice and hear answers read aloud



Deny by default: blocked chunks are filtered inside the database

0
restricted chunks ever reach the model

EXACT
totals computed in code, never guessed by the LLM

97 / 97
backend tests passing, incl. 18 attack tests

VOICE
speak your question; listen to the answer

03 · THE ARSENAL

KEY FEATURES / FUNCTIONALITY

01 SQL access gate

Tenant, grant and clearance compiled into every query. Admins get no implicit content access.

02 Row-level security

Each spreadsheet row has its own rule: same question, a different correct total per user.

03 Multimodal ingestion

PDFs, scans, photos, DOCX, XLSX, CSV, JSON. Magic-byte checks stop disguised files.

04 Injection sanitizer

Hidden “ignore previous instructions” text is stripped, the file flagged and the event audited.

05 Hybrid search + RRF

768-d vectors plus BM25, fused by rank. Finds concepts and exact IDs like EXP-1001.

06 Exact analytics

SUM, AVG, COUNT, GROUP BY run in code on authorized rows; the plan is shown.

07 Claim-level grounding

Numbers must appear in the cited chunk and ≥ 50% of words match, or the claim is cut.

08 Highlighted citations

Opens the source page or photo with the exact supporting sentence highlighted.

09 History scrub + audit

Lose access and old answers are withdrawn. Every decision is logged as ids only.

10 Policy simulator

Admins see what a user can reach and why, without seeing any document content.

11 Voice input (mic)

Tap the mic, speak naturally: live transcript and soundwave, in the browser's language.

12 Read aloud

Listen button speaks any answer in a natural voice, sentence by sentence, with pause and resume.

04 · THE EXECUTION

HOW THE SOLUTION WILL WORK

STEP 1 Ingest and sanitize files → **STEP 2** SQL permission gate → **STEP 3** Search or compute → **STEP 4** Verify, cite, speak

INGEST

- **Upload** — Size and type limits; admin sets grants
- **Magic-byte check** — %PDF, PNG, JPG, PK headers stop disguised files
- **Extract** — PyMuPDF text and tables; Gemini Vision or RapidOCR for scans
- **Sanitize** — Injection text removed, file flagged, audited
- **Chunk** — 900 chars prose; one row per chunk for sheets
- **Embed + index** — 768-d vectors, BM25 / tsvector, row rules

ASK

- **Question** — Typed or spoken via the mic
- **Identity** — Signed JWT only; body fields ignored
- **SQL gate** — Document rule AND row rule, inside the query
- **Track A** — Exact math in code
- **Track B** — Hybrid search + RRF
- **Grounded answer** — Gemini JSON; points cite evidence ids
- **Claim check** — Numbers + ≥50% words must match
- **Answer** — Highlight, Listen button, audit log

05 · THE GEAR

TECHNOLOGY / TECH STACK

Layer	Technology	Why we chose it
Frontend	React 18, TypeScript, Vite, Tailwind, Framer Motion	Typed UI, fast builds, smooth demo
Backend	Python, FastAPI, SQLAlchemy, PyJWT	Async API; identity only from signed tokens
Database	PostgreSQL + pgvector + tsvector; SQLite demo	Vectors and access rule in one SQL query
AI models	Gemini (answers, 768-d embeddings, vision)	Schema-constrained JSON; local mode offline
Documents	PyMuPDF, openpyxl, RapidOCR	Text, tables, charts, scans and sheets
Voice	Web Speech API (SpeechRecognition, speechSynthesis)	Mic input and read-aloud with no extra server
Retrieval	BM25 + vector search, Reciprocal Rank Fusion (k = 60)	Concepts and exact IDs both rank well
Hosting	Render (API + static site), Docker Compose	One-file deploy via render.yaml
Testing	pytest: 97 tests, 18 attack tests; live suite in UI	Proof the rules hold on every change

06 · INSIDE THE MINT

CURRENT PROGRESS / WORK DONE

COMPLETED

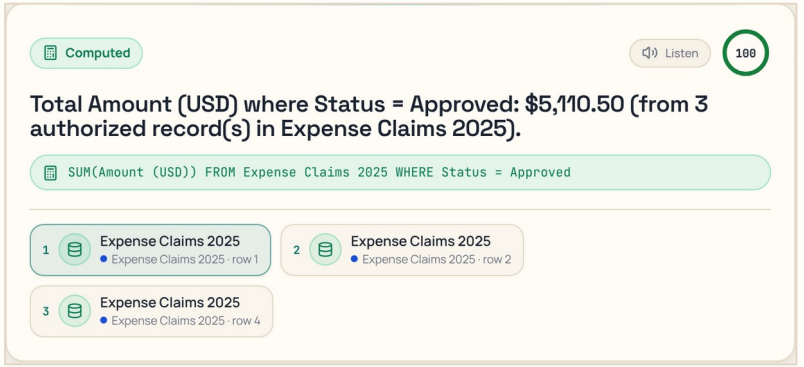
- SQL access gate, row rules, 2-tenant isolation
- Ingestion: PDF, scans, photos, DOCX, sheets
- Hybrid search, RRF and exact analytics
- Claim checks + highlighted citations
- History scrubbing, audit log, simulator
- Voice input and read-aloud in chat
- 97 / 97 tests; live attack suite 28 / 28

IN PROGRESS

- Gemini tuning within free-tier rate limits
- Cleaner table layout in answers
- Catching rephrased injections

PROOF, MEASURED TODAY

97/97	backend tests pass in 16 s
28/28	live attack tests in the UI
0	restricted chunks sent to the model



Exact total with its SQL plan and a Listen button



Voice input: live listening with soundwave

07 · THE GETAWAY

FUTURE PLAN / NEXT STEPS

PHASE 1

DURING THE HACKATHON

- Deploy live on Render with Gemini
- Fix answer table layout
- Run the attack suite live on stage
- Voice demo end to end

PHASE 2

RIGHT AFTER

- Okta / Entra ID sign-in with SCIM role sync
- Reranker after RRF
- Malware scanning of uploads
- Shared rate limits (Redis)

PHASE 3

LONG-TERM VISION

- Audio and meeting transcripts with speaker-level access
- Pilot with one college or company department
- Per-seat SaaS plus a self-hosted option

IMPACT WE AIM FOR

Teams adopt AI search without new data-leak risk

Auditors can prove who saw what, and when

Runs fully offline for air-gapped organisations

08 · THE VAULT

GITHUB REPOSITORY LINK

https://github.com/Navadeep44/aegisrag-2

PUBLIC

Repository visibility is set to public.

README

Covers setup, features, demo accounts and tests.

COMMITS

Regular commits from both team members.

DEMO (OPTIONAL)

Run locally in two commands (see README); Render config included.